# Containment proposal review

Independent reviewer exercise / four minutes / keep page 2 sealed

## Operator intent

Deny new east-west communication from the payments namespace while preserving known dependencies. Prevent privilege escalation. Restrict the compromised workload's Kubernetes API access. Preserve availability, stage the rollout and time-box exceptions.

## Proposed change

One generated privilege policy with Audit, Warn and Deny manifests. Six fixed positive/negative Pod CREATE privilege tests pass. The proposal includes no network control or RBAC change.

| Requirement | Model choice / routing | Score |
|---|---|---|
| Network restriction | Privilege escalation | 0.8986 |
| Privilege escalation | Privilege escalation | 0.8574 |
| Kubernetes API access | Human review | 0.5895 |
| Rollout and expiry | Privilege escalation | 0.9107 |

These are recorded Laya answer-confidence scores. The 0.6 cutoff accepts three clauses. Temperature fitting on a separate synthetic set does not establish calibration for this incident distribution. This example was selected after a failed run.

## Your review disposition

Approve a bounded subset / request revision / require evidence / reject

Scope and authority granted: _____

Outstanding requirement and owner: _____

Acceptance test and rollback condition: _____

Explain which evidence would change your decision. Compare your reasoning with another reviewer at the table.

# Review findings

Sealed reveal / open after tables record their disposition

### Independent ledger: INCOMPLETE_PROPOSAL

The privilege tests pass. The model chose the wrong control for networking and rollout/expiry. The API-access requirement remains unresolved. A passing suite for one generated control does not cover the other requirements.

| Requirement | Enforcement owner / required evidence |
|---|---|
| Network restriction | Network/security owner: dependency-aware NetworkPolicies and positive/negative connection probes on the target CNI. |
| API access | Identity/security owner: effective RBAC, exposed-credential response and authorization tests for the actual principal. |
| Rollout and expiry | Incident commander and service owner: availability floor, evidence custody, scoped approval, verified revocation and rollback. |

### Independent-review credit: up to three points

One point for stating the limited scope of the six privilege tests. One point for mapping an omitted requirement to its actual enforcement owner and acceptance evidence. One point for justifying the authority granted with an operational constraint and rollback criterion.

A team may justify deploying a reviewed, bounded privilege control while escalating the other requirements. It must document the remaining exposure and must not declare the incident contained. There is no universal vote that earns every point.

### Control library reference

ACG-NET-001 requires CNI evidence. ACG-IAM-001 requires RBAC and credential response. ACG-GOV-001 requires rollout and expiry evidence. Catalog metadata identifies review obligations; it does not execute these tests or authorize deployment.

### Model acceptance result

On the separate 33-choice runtime-order pilot, base and trained Laya each scored 16/33. The cutoff accepted 2 base answers and 21 trained answers, with 6 wrong among the latter. This small author-labelled pilot does not establish a universal model ranking.

Source: submission/2026-10-13/laya-training/workflow-cost/run-1/agent-run.json, readiness.json and tests/result.txt; controls/catalog.json. Local training and fixture results, not live containment or a controlled human-versus-model benchmark.